The need to make cross-origin requests from JavaScript is increasingly common with the rise of client-side SPAs and the move away from monolithic apps. Luckily, there's a web standard that lets you work around this in a safe way; this standard is CORS. You can use CORS to control which apps can call your API, so you can enable scenarios like this one.

29.3.1 Understanding CORS and how it works

CORS is a web standard that allows your web API to make statements about who can make cross-origin requests to it. For example, you could make statements such as these:

- Allow cross-origin requests from https://shopping.com and https://app .shopping.com.
- Allow only `GET` cross-origin requests.
- Allow returning the `Server` header in responses to cross-origin requests.
- Allow credentials (such as authentication cookies or authorization headers) to be sent with cross-origin requests.

You can combine these rules into a *policy* and apply different policies to different endpoints of your API. You could apply a policy to your entire application or a different policy to every API action.

CORS works using HTTP headers. When your web API application receives a request, it sets special headers on the response to indicate whether cross-origin requests are allowed, which origins they're allowed from, and which HTTP verbs and headers the request can use—pretty much everything about the request.